genetec-firmware-threat-brief

Genetec Security Center (Omnicast / Synergis) — Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory (OSINT) research only — the firmware/software itself **was acquired** via VirusTotal Intelligence into the known-good baseline (*update 2026-10-27; see the behavioural-differential section where present*), though not fully rootfs-extracted. Every finding below comes from public vulnerability disclosures (NVD, CISA ICS advisories, vendor PSIRT) and product documentation. CVE IDs listed in the Confirmed table were each independently re-verified against NVD/CISA/vendor records before inclusion; candidate IDs that could not be confirmed were dropped, not guessed.

> **Lineage / cross-reference.** Synergis Cloud Link is a Mercury-OEM access controller channel; see mercury-security-firmware-threat-brief.md for the underlying panel firmware.

Identity

Field	Value
Census / OUI string	`Genetec Inc.`
Operating company	Genetec Inc. — privately held physical-security software/appliance maker headquartered in Montreal, Quebec, Canada (founded 1997). The census string maps directly to the real company; no rebrand or parent indirection.
OT devices (ARNG census)	66 across 7 states
Genuine OT vendor?	Yes
Purdue placement	Spans Purdue Level 0-3. Edge/field: IP cameras, ALPR (Sharp/SharpV) units, card readers, door locks and I/O = Level 0-1; access-control and video field controllers (Synergis Cloud Link, Archiver edge, AutoVu units) = Level 1-2. Management/supervisory: Security Center Directory, Archiver, Media Router, SQL Server backend, Security Desk/Config Tool clients, and Streamvault appliances = Level 2-3 (site/security operations). In converged deployments the servers typically sit at Level 3 or an IT/OT DMZ (3.5) with SaaS federation reaching outbound to the cloud, so the Directory/Media Router servers are the IT-OT boundary tier an OT-SOC should watch most closely.

Identity note. The OUI/registered name "Genetec Inc." resolves cleanly to the operating company Genetec Inc. (Montreal) — it is NOT an OUI artifact or an IT vendor misfiled as OT. Genetec is a genuine physical-security (PSIM/VMS/access-control) vendor whose devices legitimately live on OT/security networks. Caveat on census identity: a large share of devices tagged "Genetec" by OUI/registered name are most likely Genetec's own turnkey appliances (Streamvault NVR/server appliances) and Synergis access-control

controllers (e.g. Synergis Cloud Link) rather than cameras — Genetec is primarily a software company and frequently rides on third-party camera/edge hardware (Axis, Bosch, Hanwha, etc.), so some endpoints a census attributes to "Genetec" may be Genetec-branded or Genetec-managed hardware whose NIC OUI belongs to the actual OEM, and conversely cameras from other OUIs may be Genetec-managed. 66 devices across 7 US states is consistent with a mid-size unified-security deployment (NVR appliances + access controllers + ALPR units) rather than a single chip vendor appearing everywhere.

Product lines & OT relevance

Genetec is a tier-1 unified physical-security platform used across government, transportation, utilities, airports, and critical-infrastructure sites — exactly the environments a National Guard OT-SOC defends. Its systems govern physical access (door controllers, readers, locks), video surveillance (VMS/NVR), and license-plate/vehicle recognition, i.e. the physical-security layer that converges with OT. Compromise of a Genetec Directory or Synergis access controller can unlock doors, disable or tamper with surveillance, and provide lateral pivot from the IT/security VLAN into OT segments. Genetec also ships an explicitly OT-adjacent "Genetec Industrial IoT" product and an "Airport Operational Manager," broadening its OT footprint beyond classic guard-force security.

- Security Center — the unified flagship platform, comprising: Omnicast (IP video management / VMS), Synergis (IP access control, incl. Synergis Cloud Link controller), and AutoVu (ALPR / automatic license-plate recognition, incl. SharpV/Sharp cameras and the ALPR Manager role)
- Security Desk / Config Tool — operator client and admin/config client
- Core server roles: Directory (central auth/config, TCP 5500/TLS), Archiver (video recording), Media Router (stream routing/RTSP), Web SDK / SDK roles, Genetec Update Service
- Streamvault — turnkey Windows-based NVR/server appliances (e.g. SV-100E/300E/350E/1000/4000E) that run Security Center preloaded; managed via SV Control Panel
- Security Center SaaS / Stratocast — cloud-hosted VMS and access control (federates on-prem via *.gsc-cloud.com / gscloud.com)
- ClearID — self-service access-control/identity management
- Mission Control — collaborative decision-management / PSIM incident engine
- Sipelia — SIP-based intercom/communication management
- Genetec Industrial IoT — OT/IIoT-oriented product (confirmed as an affected product in CVE-2026-25112)
- Airport Operational Manager, Restricted Security Area (RSA) Surveillance, Inter-System Gateway — vertical/edge modules (all affected products in CVE-2026-25112)
- Genetec RabbitMQ — bundled AMQP message-bus component used for inter-service messaging

Attack surface

- Windows-based server roles: entire Security Center stack runs on Windows Server / Windows (incl. Streamvault appliances), so it inherits Windows attack surface — SMB, RDP, LSASS creds, local privilege escalation. Multiple verified CVEs are Windows local-priv-esc in the Genetec Update Service and bundled RabbitMQ (CVE-2025-1787, CVE-2025-1789, CVE-2026-25112).

- Directory service (TCP 5500, TLS 1.2 via Genetec.Directory.exe): central authentication and configuration broker; the Server Admin credential store is a prime target (CVE-2026-40619 lets a local-OS-privileged attacker on the main server reach Server Admin credentials).
- Media Router / RTSP streaming: TCP 554 (RTSP live/playback/announce), 555 (Archiver stream requests), 560, 605 (edge playback, plain RTSP), 960 (new installs 5.8+), legacy 5004 (5.6/5.7). RTSP and multicast video are classic interception/DoS targets, especially where TLS is not enforced.
- Web SDK / SDK roles: network-facing API that has permitted remote arbitrary code execution on the host (CVE-2024-7059, CVSS 8.0/8.9).
- ALPR Manager role: critical remotely exploitable auth bypass granting admin over Security Center (CVE-2025-43027, CVSS 9.8).
- Bundled RabbitMQ (AMQP) message bus: deployed with insecure permissions enabling local privilege escalation across many Genetec products (CVE-2026-25112, CWE-732).
- Synergis Cloud Link access controllers and proxied edge devices: HTTPS/443 web admin; historically a common place for default/weak credentials on the appliance and on downstream readers/door modules; controllers can hold door-unlock authority.
- Third-party edge devices (cameras, ALPR, intercoms) managed via ONVIF, proprietary camera protocols, and SIP (Sipelia) — default camera credentials proxied through the VMS are a recurring exposure.
- SQL Server backend: Security Center stores config/events in SQL Server; weak SA creds or exposed 1433 extend the attack surface.
- Internet exposure: Genetec explicitly warns against exposing Security Center directly to the internet and recommends a trusted VPN — internet-reachable Directory/Web SDK/SaaS-federation endpoints are a real-world exposure pattern.
- Default-credential history: Security Center's built-in 'admin' Directory account historically shipped with no/weak password; Streamvault appliances and Synergis units ship with known default local accounts that are frequently left unchanged.

Confirmed CVEs / advisories

Each row was re-verified against an authoritative record (URL given). This is the public disclosure history, not an exhaustive list.

CVE / advisory	Applies to	Summary	Source
`CVE-2025-43027`	Directly affects Genetec Security Center (AutoVu/ALPR Manager role) — a core product in th	Critical (CVSS 3.1 9.8) vulnerability in the ALPR Manager role of Security Center that could allow attackers to gain administrative access to the Genetec Securi	https://nvd.nist.gov/vuln/detail/CVE-2025-43027
`CVE-2024-7059`	Directly affects Genetec Security Center's Web SDK role. Network-facing RCE on a security-	High-severity vulnerability (CVSS 3.1 8.0 / CVSS 4.0 8.9) that can lead to arbitrary code execution on the host running the Web SDK role in the Genetec Security	https://nvd.nist.gov/vuln/detail/CVE-2024-7059

CVE / advisory	Applies to	Summary	Source
`CVE-2026-40619`	Directly affects Genetec Security Center main server (Directory host). Privilege-escalatio	High-severity vulnerability (CVSS 3.1 7.8) in Security Center main-server installations allowing an attacker with local OS privileges on the main server to acce	https://nvd.nist.gov/vuln/detail/CVE-2026-40619
`CVE-2026-25112`	Affects the shared RabbitMQ component bundled across many Genetec products, including the	High-severity vulnerability (CVSS 3.1 7.8, CWE-732 incorrect permissions) in the deployment of the bundled Genetec RabbitMQ message broker allowing local privil	https://nvd.nist.gov/vuln/detail/CVE-2026-25112
`CVE-2025-1789`	Affects the Genetec Update Service, a component present on Security Center/Streamvault hos	Local privilege escalation in the Genetec Update Service (CVSS 3.1 7.8 / CVSS 4.0 5.8). An authenticated, low-privileged Windows user could exploit it to gain e	https://nvd.nist.gov/vuln/detail/CVE-2025-1789
`CVE-2025-1787`	Affects the Genetec Update Service component on Genetec hosts. Lower severity on its own b	Information leak from the Genetec Update Service configuration web page (CVSS 3.1 4.2 / CVSS 4.0 5.8, Medium). An authenticated admin-privileged Windows user co	https://cveawg.mitre.org/api/cve/CVE-2025-1787

Detection guidance

- Inventory & baseline every Genetec host: Streamvault appliances and Security Center servers are Windows boxes — enroll them in Windows event-log collection (Security, System, Sysmon) and watch for LSASS access, new local admins, service installs, and the Genetec Update Service / RabbitMQ service behaving abnormally (covers the local-priv-esc CVEs).
- Monitor/allowlist TCP 5500 (Directory, TLS 1.2): should only be spoken between known Security Center servers, Security Desk/Config Tool clients, and federated servers. Alert on any new source talking 5500, and on 5500 traffic that is not TLS.
- Watch Media Router / RTSP ports TCP 554, 555, 560, 605, 960 (and legacy 5004 on 5.6/5.7): pin expected camera->Archiver->client flows; alert on unexpected RTSP sources/destinations, plaintext RTSP where TLS is expected, and large off-hours stream pulls (video exfiltration / tamper).
- AMQP/RabbitMQ: if present, lock down 5671 (AMQPS) / 5672 (AMQP) and the management UI (15671/15672) to localhost or the server cluster only; alert on any remote AMQP connection (CVE-2026-25112 is local, but exposed broker ports are a red flag).
- HTTPS/443 to Synergis Cloud Link controllers and the Web SDK role: restrict admin access to a management jump host; alert on Web SDK calls from unexpected sources (CVE-2024-7059 RCE vector) and on ALPR Manager administrative actions (CVE-2025-43027).
- ONVIF / WS-Discovery (UDP 3702) and camera-management traffic: baseline which hosts discover/manage cameras; alert on new discovery sources that could indicate rogue enrollment.
- SaaS federation egress: if Security Center SaaS/Stratocast is used, allowlist outbound only to the documented *.gsc-cloud.com / Genetec cloud endpoints on 443; alert on any other outbound from security servers.

- SQL Server 1433: should never be reachable from the general network — restrict to the Security Center server tier and alert on external 1433 connections.
- Log sources to pull: Security Center / Security Desk audit trails and activity trails (door-unlock, config changes, role changes, user logons), Streamvault SV Control Panel logs, Windows event logs, SQL audit, and RabbitMQ logs. Correlate physical door-unlock events with badge/identity events for anomaly detection.
- Patch-state detection for CVE-2026-40619 specifically: version number alone is insufficient (same version shipped vulnerable and fixed builds) — verify installation-package build hashes against Genetec's advisory list rather than trusting the displayed version string.

Acquisition status

We currently hold NONE for this vendor. Genetec software and appliance firmware are GATED, not openly downloadable. Full installers, patches, SDKs, and Streamvault firmware/OS/recovery images are distributed through the Genetec Technical Assistance Portal (GTAP, portal.genetec.com) which requires a valid customer/partner account (and often an active SMA/Advantage support contract). Streamvault appliances ship preloaded with Security Center and self-update via the SV Control Panel / Streamvault Update plug-in and the Genetec Update Service pulling from GTAP; factory recovery is done from a vendor-provided bootable USB image. There is no public anonymous download channel; marketing datasheets/brochures (resources.genetec.com) and the TechDocs documentation site (techdocs.genetec.com) are public, but binaries are not. Realistic acquisition paths for our corpus: (a) the end-user National Guard unit's own GTAP entitlement / support contract; (b) a Genetec channel partner; (c) imaging an in-scope Streamvault appliance or Synergis controller already on the network (requires authorization). Security advisories themselves are public at resources.genetec.com/security-advisories and are the best open OSINT source for this vendor.

Notes

Research date 2026-10-26. All six CVEs were verified in THIS research against the live NVD REST API (services.nvd.nist.gov/rest/json/cves/2.0?cveId=...), which returned full records with sourceIdentifier security@genetec.com, CVSS vectors, affected-product lists, and vendor advisory references; the cve_claims URLs point to the canonical NVD detail pages for those same records. Each CVE also carries a Genetec security-advisory reference (resources.genetec.com/security-advisories/... and techdocs.genetec.com for the Update Service pair). No CISA/ICS-CERT advisory for Genetec was found in this search — Genetec self-publishes advisories as a CNA (security@genetec.com) rather than via ICS-CERT, so CISA absence is expected, not a gap. No CVE ID was guessed or recalled from memory; anything unverifiable was omitted. Port numbers are from Genetec TechDocs (techdocs.genetec.com) default-port tables for Security Center 5.12/5.13 and are version-specific — confirm against the installed release before writing firewall rules. Given we hold NO firmware for this vendor, this brief is OSINT/advisory only; the single most actionable OSINT follow-up is monitoring resources.genetec.com/security-advisories, and the single most important patch-verification nuance is that CVE-2026-40619 requires build-hash checking rather than version-string comparison.

Status

Item	State
Firmware/software acquired	**No** — OSINT/advisory only
Confirmed CVEs	6 (independently re-verified)
Behavioural baseline	None — no samples held
Next step	CISA/PSIRT deep pass; attempt firmware acquisition

Generated 2026-10-26 from the ot-vendor-briefs workflow (12 researchers + adversarial CVE verification). Device counts from the 2026-10-22 ARNG OT census.

VT behavioural differential — Genetec corpus (2026-10-27)

Generated by `tools/Invoke-VendorDifferential.ps1` against the Genetec known-good baseline (NSRL + local, platform-matched) and the VT malicious target set (17281 targets). Each behaviour is scored by how **rare** it is in this vendor's own known-good software: `rarity 100` = the baseline *never* exhibits it; a lower score = the baseline does, so it is scored down as benign-common.

> **Read this correctly.** The sparse OT baseline means the rarity-100 list is dominated by *generic* malicious behaviour, not Genetec-specific indicators — any comparable malware trips most of it. The genuinely Genetec-specific product of this differential is the **suppression list** at the end: behaviours this vendor's real software performs, which must **not** be alerted on when monitoring a host that runs it. Use the MITRE table as the TTP-tier hunting frame; use the suppression list to cut false positives.

Category	Behaviours observed	Discriminating (rarity 100)	Benign-common (suppressed)
MITRE ATT&CK	3068	3068	0
Windows API	17613	16235	1378
Process/cmdline	18066	18066	0
Registry	121570	121570	0
Mutex	4946	4946	0
YARA	2874	2869	5
Sigma	959	949	10
Certificate	1769	1766	3
Tags	346	295	51

Top discriminating MITRE ATT&CK techniques

Techniques present in the malicious corpus and **absent from the Genetec known-good baseline**, ranked by how many malicious samples exhibit each.

Technique	Malicious samples	Last seen
T1082: Reads software policies	1391	2026-03-16
T1071: Adversaries may communicate using application layer protocols to avoid detection/network filtering by blending in with existing traffic.	1078	2026-03-16
T1082: Queries the volume information (name, serial number etc) of a device	874	2026-03-16
T1497: May sleep (evasive loops) to hinder dynamic analysis	836	2026-03-16
T1129: link function at runtime on Windows	758	2026-02-04
T1574.002: Tries to load missing DLLs	729	2026-03-16
T1518.001: May try to detect the virtual machine to hinder analysis (VM artifact strings found in memory)	689	2026-03-16
T1036: Creates files inside the user directory	643	2026-03-16
T1083: Reads ini files	585	2026-03-16
T1497: Contains medium sleeps (>= 30s)	580	2026-03-16
T1082: An adversary may attempt to get detailed information about the operating system and hardware, including version, patches, hotfixes, service packs, and architecture.	573	2026-03-16
T1497: Contains long sleeps (>= 3 min)	561	2026-03-16

Highest-prevalence behavioural discriminators (top 5 per type)

Behaviour	Type	Malicious samples
HKEY_LOCAL_MACHINE\Software\Microsoft\Ole	Registry	1744
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session Manager	Registry	1467
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\Shell Fol	Registry	1176
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session Manager\Segment He	Registry	912
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\AppModel\Lookaside\Packages	Registry	901
C:\Windows\System32\conhost.exe C:\Windows\system32\conhost.exe 0xffffffff -Fo	Process/cmdline	732
C:\Windows\system32\services.exe	Process/cmdline	598
C:\Windows\System32\wuapihost.exe	Process/cmdline	380
C:\Windows\Explorer.EXE	Process/cmdline	365
C:\Windows\system32\lsass.exe	Process/cmdline	293
MSVCRT.dll!memcpy	Windows API	1056

Behaviour	Type	Malicious samples
kernel32.dll!PostQueuedCompletionStatus	Windows API	965
kernel32.dll!FindResourceA	Windows API	871
KERNEL32.dll!SetWaitableTimer	Windows API	866
kernel32.dll!GetWindowsDirectoryA	Windows API	805
Local\ZonesLockedCacheCounterMutex	Mutex	465
Local\ZonesCacheCounterMutex	Mutex	463
\Sessions\1\BaseNamedObjects\Local\SessionImmersiveColorMutex	Mutex	279
\Sessions\1\BaseNamedObjects\Global\SyncRootManager	Mutex	263
\Sessions\1\BaseNamedObjects\Local\ZonesCacheCounterMutex	Mutex	226

Benign-common behaviours — suppress for this vendor (do NOT alert)

These appear in the Genetec known-good baseline, so the differential scores them down and they should not drive alerts on a host running genuine Genetec software. `base%` = share of the baseline exhibiting the behaviour. (1432 suppressed in total; top 15 shown.)

Behaviour	Type	base%	rarity
No Sig	Certificate	86.958%	13
known-distributor	Tags	39.298%	61
png	Tags	26.3593%	74
overlay	Tags	12.8699%	87
signed	Tags	12.5946%	87
pedll	Tags	11.1149%	89
assembly	Tags	10.5299%	89
mscoree.dll!_CorDllMain	Windows API	10.2891%	90
android	Tags	8.8438%	91
legit	Tags	3.5788%	96
text	Tags	2.8562%	97
kernel32.dll!GetCurrentProcess	Windows API	2.3056%	98
KERNEL32.dll!GetProcAddress	Windows API	2.2712%	98
KERNEL32.dll!WideCharToMultiByte	Windows API	2.2712%	98
KERNEL32.dll!MultiByteToWideChar	Windows API	2.2712%	98